CASE STUDY

The Dot-Com Era: Cyber Events, 1994 to 2003

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

A lot of people in our community started their careers somewhere between Melissa and Blaster. The help desk that spent a weekend pulling Word macros out of mail queues, the web team that rebuilt an IIS box after Code Red, the network engineer who watched a single UDP packet take a campus offline in January 2003: those years built the habits the profession still runs on, from the CVE number on every ticket to the idea that a company should tell customers when their card numbers walk out the door. This study reads that decade, from the Citibank transfers of 1994 to the Blaster arrest in 2003, against the records that survive: CERT/CC advisories and incident notes, Microsoft security bulletins, NVD records, Justice Department releases, statutes, SEC filings, Senate records, and the network measurements CAIDA and its partners published at the time.

The record shows three things clearly. First, the era's biggest worms used flaws that already had a fix. Microsoft published MS01-033 on 18 June 2001, about four weeks before Code Red; MS02-039 on 24 July 2002, six months before Slammer; and MS03-026 on 16 July 2003, 26 days before Blaster (Confirmed [32][38][43][40]; the gaps are computed, Inferred). Melissa was not known to exploit any new vulnerability; it needed a person to open a document (Confirmed [21]). Second, the speed of the threat outran human response: CAIDA measured Code Red version 2 infecting 359,104 hosts in under fourteen hours, and Slammer reaching more than 90 percent of vulnerable hosts in about ten minutes, doubling roughly every 8.5 seconds in its first minute (Demonstrated [35][42]; Confirmed [41]). Third, the institutions we now take for granted were assembled in response, in a short span: the CVE List launched in September 1999, PDD-63 encouraged a private-sector Information Sharing and Analysis Center in 1998, the Budapest Convention was done at Budapest in November 2001, Microsoft's Trustworthy Computing memo went out in January 2002, California's breach-notification law became operative in July 2003, and CAN-SPAM was approved in December 2003 (Confirmed [59][72][70][67][92][77]; the memo's text is Reported [66]).

The era also had a quieter, longer story. Kaspersky and King's College London researchers report that the intrusions the US called Moonlight Maze ran through military, research and university networks from 1996, relayed through hacked servers, with recovered binaries for SPARC Solaris and MIPS IRIX (Confirmed [13]). They trace a later Turla backdoor to the same 1990s open-source code base, and they also say a conclusive link is premature (Reported [13]). The loud events of the decade were mostly teenagers, worm authors and extortionists. The long espionage campaign of the same years, which the Kaspersky researchers place among the pioneers of state-sponsored cyberespionage, is the part the public record still holds least of (Reported [13]).

> Evidence grade: the worms, the vulnerabilities and fixes, the prosecutions, the statutes and the filings are **Confirmed** from CERT/CC, Microsoft, NVD, DOJ, the Council of Europe, Congress, the SEC and other primary records. The network measurements are **Demonstrated** where CAIDA published its own data. The Citibank transfers, the Solar Sunrise profile, the February 2000 denial-of-service attacks, the Mafiaboy sentence, the ILOVEYOU prosecution and most damage figures are known only from press and reference works and are **Reported** and attributed. Every ATT&CK mapping is this study's reading of the record and is **Inferred**.

Key facts at a glance

Field	Value
Period	1994 (Citibank transfers) to 2003 (Blaster, CAN-SPAM), with context back to 1978 and forward to 2005
Biggest measured worm spread	Code Red v2: 359,104 hosts in under 14 hours on 19 July 2001 [35]; Slammer: more than 90 percent of vulnerable hosts within 10 minutes on 25 January 2003, at least 75,000 hosts [41][42]
The three worm CVEs	CVE-2001-0500 (Code Red, MS01-033), CVE-2002-0649 (Slammer, MS02-039), CVE-2003-0352 (Blaster, MS03-026) [32][38][43]
Fix before outbreak	About 4 weeks (Code Red), about 6 months (Slammer), 26 days (Blaster); computed from the dated records, Inferred [32][38][43][40]
Weakness on record	NVD lists CWE-119 for CVE-2002-0649 only; CVE-2001-0500 and CVE-2003-0352 carry NVD-CWE-Other [39]
Convictions on record	Mitnick (46 months, 1999) [3]; Smith for Melissa (20 months, 2002) [22]; Gorshkov (36 months, 2002) [87]; Ivanov (48 months, 2003) [88]; Parson for a Blaster variant (18 months, 2005) [45]
Market backdrop	NASDAQ Composite 743.58 on 3 January 1995, 5,048.62 peak close on 10 March 2000, 1,114.11 low close on 9 October 2002 [79]
Institutions born	CVE List (September 1999) [59]; PDD-63 (22 May 1998) [72]; Budapest Convention ETS 185 (23 November 2001) [70]; DHS (opened 1 March 2003) [74]; California SB 1386 (operative 1 July 2003) [92]; CAN-SPAM (16 December 2003) [77]
ATT&CK objects	No group, software or campaign object exists for any worm, virus or intrusion in this study; Turla (G0010) and Penquin (S0587) enter only as an unproven Moonlight Maze lineage [13][14][96]
Home study for Mitnick	Kevin Mitnick: Ghost in the Wires and The Art of Intrusion

Key findings

- **The big worms were patching failures, not zero-days.** Code Red, Slammer and Blaster each exploited a flaw Microsoft had already fixed, and Melissa used no new vulnerability (Confirmed [32][38][43][21]). The gaps between fix and outbreak ran from 26 days to six months (Inferred from the dated records).
- **Defaults did much of the damage.** IIS 5.0 installed by default on Windows 2000 Server, RPCSS ran by default in every Windows version, and CERT/CC reported thousands of Windows systems compromised through null or weak Administrator passwords in 2003 (Confirmed [32][43][40]).
- **Speed changed the defender's job.** Slammer spread two orders of magnitude faster than Code Red, whose doubling time was 37 minutes (Confirmed [41]). CAIDA concluded that techniques other than host patching are required to mitigate worms (Demonstrated [35]).
- **The patch only went on after the pain.** CAIDA's 14 August 2001 survey found patching among Code-Red-infected hosts rose from 32 percent to 64 percent only after the 1 August resurgence (Demonstrated [35]).

- **Most damage figures are claims.** Melissa's "more than $80 million" is a figure Smith admitted in his plea; CAIDA repeats a third party's $2.6 billion Code Red cost rather than measuring it; and the Crown prosecutor put the Mafiaboy figure near $7.5 million against billion-dollar press estimates (Confirmed [22]; Reported [35][27][28]).
- **E-commerce paid the fraud bill.** Egghead.com told the SEC that merchants bear card-not-present fraud losses even when the issuer approves the charge, and eUniverse could not say whether its insurance covered the CD Universe theft (Confirmed [85][82]).
- **The law caught up unevenly.** The ILOVEYOU charges were dismissed in August 2000 for insufficient evidence, and the new Philippine e-commerce law could not apply because the program was released before it passed; the Budapest Convention, done at Budapest in November 2001, defined the offences a treaty partner must make crimes (Reported [31]; Confirmed [30][70]).
- **The quiet threat was long-running espionage.** Moonlight Maze ran from about 1996, years before any of the headline worms, and its link to any later group remains unproven in the researchers' own words (Confirmed [13]; Reported for the attribution).

Top recommendations

1. **Patch exposed services on a clock, not on an outbreak.** Every major worm of the era followed a published fix by weeks or months (Confirmed [32][38][43]). Track time from vendor fix to deployment for internet-facing and widely listening services, and treat a gap measured in weeks as the risk it was in 2001 to 2003 (Inferred).
2. **Do not rely on patching alone.** CERT/CC said ingress and egress filtering limits damage from infected hosts but does not stop initial infection, CERT VU#568148 advised perimeter blocking of RPC and SMB ports while warning that insiders stay exposed, and Microsoft's MS01-033 recommended DMZs, minimal services and isolation of web servers from internal networks (Confirmed [51][54][32]). Segment so that one infected host cannot reach every listener on the network (Inferred).
3. **Turn off what is on by default and change what ships weak.** Default IIS, default RPCSS and null Administrator passwords were the paths in (Confirmed [32][43][40]). The library's D3FEND pages for Change Default Password and Strong Password Policy cover the countermeasures (Confirmed [96]).
4. **Treat mail and macros as an execution path.** CERT/CC's Melissa advice was to block the signature at mail transfer agents, keep scanners updated and have users disable Word macros (Confirmed [49]). The modern equivalents are Email Filtering and Executable Allowlisting (Confirmed [96]; Inferred pairing).
5. **Filter spoofed traffic at your edge.** Five weeks before the February 2000 attacks, CERT/CC and FedCIRC urged patching and RFC 2267 ingress filtering against the source-address spoofing the DDoS tools used (Confirmed [29]).
6. **Plan for breach notice before you need it.** CD Universe could not determine when or how its data was taken and treated every customer as possibly affected (Confirmed [82]). California's SB 1386 made notice of a breach of unencrypted personal information a legal duty from July 2003 (Confirmed [92]).
7. **Name and time your vulnerabilities the way the community does.** Use CVE identifiers in every ticket, the reason the list was proposed in 1999, and a published disclosure timeline such as CERT/CC's default of 45 days (Confirmed [58][64]).

Scope and method

This study covers cyber events from 1994 to 2003, the years of the commercial web's rise and the dot-com market's peak and collapse, with context reaching back to 1978 and forward to the 2005 Blaster sentence. It covers five lenses: the attack record; the technology and defense record (CERT/CC, CVE, disclosure norms, Microsoft's patch and development changes); law and policy; the business dimension (the market, e-commerce fraud, spam and insurance); and the defender view, including the MITRE mappings. Kevin Mitnick's 1995 arrest and prosecution belong to the library's Mitnick study, which is the home for that record; this study summarizes it in one paragraph. This study is the home for the CD Universe, Egghead.com and Gorshkov and Ivanov records until a dedicated e-commerce study lands; that study should summarize them in one paragraph and link here. The 1986 intrusion at Lawrence Berkeley Laboratory and the 1988 worm, the year CERT/CC began, belong to The Cuckoo's Egg Intrusion and Five Hacks and Why They Worked.

Every source was opened on 11 November 2026. Quotations are kept to a few words. Tradecraft is described at the level the CERT/CC advisories use: technique names and identifiers, never commands, payloads or exploit details.

Grade	Meaning
Confirmed	A primary source was opened: a CERT/CC advisory, incident note or vulnerability note, a Microsoft bulletin, an NVD record, a DOJ release or court record, a statute or treaty text, an SEC filing, a Senate committee record, a government strategy or report, a security vendor's report of its own findings, or the MITRE record and the library's data files
Reported	Known only through a secondary source: press coverage, reference works, a later account by an unnamed participant, or a primary that relays someone else's figure
Demonstrated	A public measurement or archive shows the thing directly: CAIDA's published infection and patching data, and the surviving mailing-list archives
Inferred	This study's own reasoning from the cited facts, including every ATT&CK, CWE, CAPEC and D3FEND mapping choice, labelled where it appears

Where sources disagree on a number or a date, the study gives both and says which the primary record supports (see Part 3, "Discrepancies in the record"). Dates are given as each source states them.

Part 1: the timeline

One row per dated event or report. Rows before 1994 and after 2003 are context.

Date	Event	Grade	Source
3 May 1978	Earliest documented email spam: a DEC message about DEC-20 receptions sent to West Coast ARPANET addresses, reported by Einar Stefferud	Reported	[89]
1988	Mitnick pleads guilty federally over Digital Equipment Corporation intrusions; 12 months plus three years of supervised release	Confirmed	[5]
Dec 1988	CERT/CC issues its first advisory, CA-1988-01 (ftpd, with a sendmail item), citing problems or attacks in the past few weeks	Confirmed	[48]

Date	Event	Grade	Source
31 Mar 1993	Joel Furr's first USENET use of "spam" for net abuse, after software misposted about 200 messages	Reported	[89]
16 Nov 1993	The seclists.org Bugtraq archive begins, with threads on CERT Advisory CA-93:17	Demonstrated	[60]
1994	Vladimir Levin and confederates begin transferring about $10 million from Citibank subsidiaries in Argentina and Indonesia	Reported	[1]
12 Apr 1994	Canter and Siegel's "Green Card Lottery" posting to every USENET newsgroup, the first deliberate mass posting commonly called spam	Reported	[89]
13 Sep 1994	CFAA amended by Pub. L. 103-322	Confirmed	[69]
3 Jan 1995	NASDAQ Composite closes at 743.58	Confirmed	[79]
15 Feb 1995	DOJ announces Mitnick's arrest in Raleigh, North Carolina, after a two-week electronic manhunt	Confirmed	[4]
3 Mar 1995	Levin arrested at Stansted airport	Reported	[2]
1996	Moonlight Maze intrusions begin against mainly US military, research and university networks; recovered samples compiled as far back as late 1996	Confirmed	[13]
11 Oct 1996	CFAA amended by Pub. L. 104-294	Confirmed	[69]
1 to 26 Feb 1998	Solar Sunrise: attacks on unclassified DoD networks, at least eleven against Air Force, Navy and Marine Corps systems	Reported	[10]
18 Mar 1998	DOJ announces the Israeli National Police arrest of Ehud Tenenbaum; no classified information compromised, no indication of a state-sponsored campaign	Confirmed	[9]
27 Apr 1998	Los Angeles Times reports Prime Minister Netanyahu calling Tenenbaum "damn good"; not charged as of then	Reported	[11]
19 May 1998	Senate Committee on Governmental Affairs hearing with seven L0pht members and Peter G. Neumann	Confirmed	[15][16]
20 May 1998	Ninth Circuit upholds Mitnick's supervised-release limits on computer and phone access	Confirmed	[6]
22 May 1998	PDD/NSC-63, Critical Infrastructure Protection	Confirmed	[72]
21 Jul 1998	Cult of the Dead Cow announces Back Orifice for release at DEF CON VI on 1 August	Confirmed	[17]
4 Aug 1998	Microsoft bulletin MS98-010 on Back Orifice	Confirmed	[19]
1998 to early Mar 1999	A Moonlight Maze relay server is turned into a monitoring point for about six months, until the attackers abandon it after the first publicity	Confirmed	[13]
8 Jan 1999	Mann and Christey date their paper proposing a Common Vulnerability Enumeration	Confirmed	[58]
21 to 22 Jan 1999	CVE concept presented at Purdue University	Confirmed	[59]

Date	Event	Grade	Source
Feb 1999	Tenenbaum indicted under Israeli computer crime law	Reported	[12]
Mar 1999	Mitnick's global plea	Confirmed	[3]
26 Mar 1999	Melissa reports begin about 2:00 PM GMT-5	Confirmed	[21][22]
27 Mar 1999	CERT/CC advisory CA-1999-04, Melissa	Confirmed	[21][49]
1 Apr 1999	David L. Smith arrested after a tip from AOL	Confirmed	[22]
22 Apr 1999	CERT/CC incident note IN-99-03, CIH	Confirmed	[20]
26 Apr 1999	CIH trigger date for some variants, the 13th anniversary of Chernobyl	Confirmed	[20]
9 Aug 1999	Mitnick sentenced to 46 months	Confirmed	[3]
Sep 1999	CVE List launches publicly with 321 records and a 19-member Editorial Board	Confirmed	[59]
4th quarter 1999	Census Bureau quarterly retail e-commerce series begins	Confirmed	[80]
9 Dec 1999	Smith pleads guilty in state and federal court	Confirmed	[22]
Late Dec 1999	An extortionist claiming to hold CD Universe customer data contacts eUniverse	Confirmed	[82]
28 Dec 1999	CERT/CC CA-1999-17 on the TFN2K denial-of-service tool	Confirmed	[21]
3 Jan 2000	CERT/CC and FedCIRC CA-2000-01 on DoS tool developments	Confirmed	[29]
8 Jan 2000	CD Universe customer data posted online; the FBI has the site shut down the same day	Confirmed	[82]
7 Feb 2000	Yahoo and companion sites unreachable for about three hours after what Yahoo called a distributed denial-of-service attack	Reported	[23]
8 Feb 2000	Follow-on attacks on Amazon.com, eBay, Buy.com and CNN Interactive	Reported	[24]
15 Feb 2000	Wired reports an IRC log of a 15-year-old Canadian called mafiaboy soliciting help to take down CNN	Reported	[26]
10 Mar 2000	NASDAQ Composite closes at 5,048.62, the highest close from that date through 2003	Confirmed	[79]
15 Apr 2000	RCMP arrests a 15-year-old using the name "mafia boy" in Montreal, per the Attorney General's 19 April statement	Confirmed	[25]
4 May 2000	CERT/CC CA-2000-04, the Love Letter worm	Confirmed	[29]
8 May 2000	More than 650 sites have reported more than 500,000 affected systems	Confirmed	[29]
14 Jun 2000	Philippine Republic Act 8792, the Electronic Commerce Act	Confirmed	[30]
21 Aug 2000	Philippine charges against Onel A. de Guzman dismissed	Reported	[31]
10 Nov 2000	Gorshkov and Ivanov arrive for a recorded meeting with the FBI's undercover "Invita" company in Seattle	Confirmed	[87]

Date	Event	Grade	Source
Dec 2000	Egghead.com breach by hackers; 29 organizations have declared CVE compatibility for 43 products	Confirmed	[85][59]
Jan 2001	Mafiaboy pleads guilty	Reported	[27]
Mar 2001	DOJ's US Attorneys' Bulletin presents Mitnick's release conditions as a model	Confirmed	[5]
14 Jun 2001	Tenenbaum sentenced in Israel to community service, probation and a suspended sentence	Reported	[12]
18 Jun 2001	Microsoft MS01-033 (idq.dll); CERT VU#952336 date public	Confirmed	[32][52]
About 13 Jul 2001	Code Red variants begin attacking hosts	Confirmed	[50]
19 Jul 2001	Code Red v2 begins about 10:00 UTC; CERT/CC CA-2001-19	Confirmed	[34][33]
26 Jul 2001	CERT/CC CA-2001-23: at least 280,000 hosts compromised in the first wave	Confirmed	[33]
1 Aug 2001	Code Red propagation resumes, as CERT/CC expected	Confirmed	[50][35]
14 Aug 2001	CAIDA patch survey of Code-Red-infected hosts	Demonstrated	[35]
15 Aug 2001	Egghead.com files for Chapter 11 to sell assets to Fry's Electronics	Confirmed	[86]
12 Sep 2001	Mafiaboy sentenced in Montreal to eight months of youth detention	Reported	[28]
18 Sep 2001	CERT/CC CA-2001-26, Nimda	Confirmed	[33]
Oct 2001	USA PATRIOT Act amends the CFAA	Confirmed	[69]
26 Oct 2001	First Klez infections found	Confirmed	[36]
23 Nov 2001	Council of Europe Convention on Cybercrime done at Budapest	Confirmed	[70]
Dec 2001	Visual Studio .NET team's security review, per the Gates memo	Reported	[66]
15 Jan 2002	Bill Gates's "Trustworthy computing" email to all Microsoft full-time employees	Reported	[66]
17 Jan 2002	Klez.E first found	Confirmed	[36]
Feb 2002	Christey and Wysopal submit the "Responsible Vulnerability Disclosure Process" Internet-Draft	Confirmed	[62][63]
2002	NIST SP 800-51 first released, recommending US agencies use CVE	Confirmed	[59]
1 May 2002	Smith sentenced to 20 months for Melissa	Confirmed	[22]
23 May 2002	FTC Safeguards Rule published	Confirmed	[91]
9 Jul 2002	The Full-Disclosure mailing list archive begins	Demonstrated	[65]
24 Jul 2002	Microsoft MS02-039 (SQL Server Resolution Service)	Confirmed	[38]
25 Sep 2002	California SB 1386 approved	Confirmed	[92]

Date	Event	Grade	Source
4 Oct 2002	Gorshkov sentenced to 36 months	Confirmed	[87]
9 Oct 2002	NASDAQ Composite closes at 1,114.11, the lowest close through 2003	Confirmed	[79]
25 Nov 2002	Homeland Security Act, including FISMA and the Cyber Security Enhancement Act	Confirmed	[73]
5 Dec 2002	Sophos names Klez the biggest virus of 2002	Reported	[37]
25 Jan 2003	Slammer begins slightly before 05:30 UTC; CERT/CC CA-2003-04	Confirmed	[41][40]
31 Jan 2003	MS02-039 revised: protects against Slammer, superseded by MS02-061	Confirmed	[38]
Feb 2003	National Strategy to Secure Cyberspace	Confirmed	[75][76]
1 Mar 2003	DHS opens its doors	Confirmed	[74]
11 Mar 2003	CERT/CC CA-2003-08: Windows systems compromised through weak Administrator passwords	Confirmed	[40]
30 Apr 2003	FTC "False Claims in Spam"	Confirmed	[90]
23 May 2003	FTC Safeguards Rule takes effect	Confirmed	[91]
1 Jul 2003	California SB 1386 operative	Confirmed	[92]
16 Jul 2003	Microsoft MS03-026 (DCOM RPC); CERT VU#568148 date public	Confirmed	[43][54]
25 Jul 2003	Ivanov sentenced to 48 months	Confirmed	[88]
11 Aug 2003	CERT/CC CA-2003-20, W32/Blaster	Confirmed	[40]
12 Aug 2003	Jeffrey Lee Parson releases the "teekids" Blaster variant	Confirmed	[45]
29 Aug 2003	Parson arrested	Confirmed	[44]
14 Oct 2003	Microsoft's October 2003 Security Bulletin Summary	Confirmed	[55]
11 Nov 2003	Microsoft's November 2003 Security Bulletin Summary	Confirmed	[56]
16 Dec 2003	CAN-SPAM Act approved; effective 1 January 2004 except section 9	Confirmed	[77]
23 Feb 2004	Census reports 2003 US retail e-commerce of $54.9 billion	Confirmed	[81]
2004	The SDL becomes a mandatory part of Microsoft's development process; the SDL paper is presented at ACSAC in December	Confirmed	[67]
28 Jan 2005	Parson sentenced to 18 months	Confirmed	[45]

Part 2: the intrusions

2.1 Citibank, 1994

The decade's first large financial intrusion is also one of its least documented. Britannica reports that from 1994 Vladimir Levin, with dozens of confederates, began transferring about $10 million from Citibank N.A. subsidiaries in Argentina and Indonesia to accounts in San Francisco, Tel Aviv and elsewhere (Reported [1]). Lenta.ru reports that he was arrested at Stansted airport on 3 March 1995, extradited to the US and sentenced to three years, and gives the sum as more than $12 million, of which only about $250,000 was not recovered (Reported [2]). A 2005 account by an unnamed participant, summarized by Lenta.ru, says a group first reached Citibank's network over X.25 and the access was later used by Levin (Reported [2]). No US court record or DOJ release for the case was found or opened, so the method, the sum and the sentence all rest on secondary sources here, and the study maps no ATT&CK technique to the case.

2.2 Kevin Mitnick, 1995 (summary; home study linked)

The library's home for this record is Kevin Mitnick: Ghost in the Wires and The Art of Intrusion. In short: FBI agents and the Raleigh-Durham Fugitive Task Force arrested Mitnick in Raleigh in February 1995 on a probation-violation warrant after a two-week electronic manhunt, with DOJ crediting the San Diego Supercomputer Center and Tsutomu Shimomura for significant assistance (Confirmed [4]). DOJ later described his two and a half years as a fugitive: cloned cellular phones, unauthorized access to dozens of networks, theft of proprietary software and passwords, and over 100 cloned phone codes and false IDs at arrest (Confirmed [5]). In a March 1999 global plea he admitted intrusions and the theft of proprietary software from Motorola, Novell, Fujitsu, Sun Microsystems and others, using social engineering, cloned cellular phones, sniffers and hacker software, and on 9 August 1999 he was sentenced to 46 months (Confirmed [3]). The Ninth Circuit had already upheld limits on his computer and phone access during supervised release in May 1998, and DOJ presented his release conditions as a model for hacker cases in 2001 (Confirmed [6][5]). The home study grades the victims' disputed loss claims as overstated.

2.3 Solar Sunrise, 1998

From 1 to 26 February 1998, unclassified Department of Defense networks came under a series of attacks, at least eleven of them against Air Force, Navy and Marine Corps systems, while the US prepared for possible action against Iraq (Reported [10]). GlobalSecurity.org describes a repeated profile: probe for a known operating-system vulnerability, exploit it, implant a sniffer, and return to collect the data (Reported [10]). The timing invited suspicion of a state (Inferred). The attackers were two California teenagers and one Israeli teenager (Reported [10]).

The primary record is DOJ's 18 March 1998 release: the Israeli National Police had arrested Ehud Tenenbaum for intrusions into US military systems in February, no classified information was compromised, there was no indication of an organized military or state-sponsored campaign, and the FBI had searched the homes of two California teenagers (Confirmed [9]). The Los Angeles Times reported that Prime Minister Netanyahu called Tenenbaum, "the Analyzer", "damn good", that he was suspected of breaking into as many as 700 sites worldwide, and that he had not been charged by late April (Reported [11]). The Register reported that he was indicted under Israeli computer crime law in February 1999 and sentenced in June 2001 to six months of community service, a year of probation and a two-year suspended sentence (Reported [12]).

2.4 Moonlight Maze, 1996 to 1999

Moonlight Maze is the decade's long-running espionage case, which the Kaspersky researchers describe as pioneering state-sponsored cyberespionage (Reported [13]), and it is known mostly through one later piece of research. Kaspersky's Global Research and Analysis Team and King's College London researchers report that the intruders rummaged through mainly US military, research and university networks from 1996, that recovered samples were compiled as far back as late 1996, that logs span 1998 to 1999, and that the binaries targeted SPARC Solaris and MIPS IRIX (Confirmed [13]). The operators relayed through a series of hacked servers. At one relay the system administrator, working with the Metropolitan Police and the FBI, turned the server into a monitoring point for about six months, until the attackers abandoned it after the campaign's first publicity in early March 1999 (Confirmed [13]). The same researchers report victims including the Pentagon, NASA and the Department of Energy, and relay an investigators' remark that a printout of the stolen material would stand three times taller than the Washington Monument (Reported [13]).

The researchers trace the Penquin Turla backdoor to the 1990s open-source LOKI2 code base, and they also state that a conclusive link from Moonlight Maze to Turla is premature (Reported [13]). Their dataset was one retired administrator's preserved logs and relay binaries covering about six months, they call the Turla link circumstantial, and the later "Storm Cloud" toolkit was unavailable to them (Reported [13]). ATT&CK's own pages for Turla (G0010) and Penquin (S0587) do not mention Moonlight Maze; ATT&CK describes Penquin as used by Turla against Linux since at least 2014 (Confirmed [14]). Any Moonlight Maze to Turla link in this study is Kaspersky's, attributed to Kaspersky, and the library's Russia-attributed threat actor study is the home for Turla's record. Whether any official Moonlight Maze material remains classified was not checked.

2.5 L0pht before the Senate, 1998

On 19 May 1998 the Senate Committee on Governmental Affairs held "Weak Computer Security in Government: Is the Public at Risk?" in 342 Dirksen. The witnesses were seven members of L0pht Heavy Industries, listed by handle (Brian Oblivion, Kingpin, Mudge, Space Rogue, Stefan Von Neumann, Tan and Weld Pond), and Peter G. Neumann of SRI International (Confirmed [15]). Chairman Fred Thompson's prepared statement called the hearing the first of a series on federal computer security, warned against waiting for an information-age "Pearl Harbor", and described L0pht as a hacker think tank whose members would testify on specific weaknesses (Confirmed [16]). The often-repeated line that L0pht said it could take down the Internet in 30 minutes was not checked against a transcript and is not repeated here as fact. The hearing is the community's moment of being asked in: hackers testifying under their handles as expert witnesses, three days before PDD-63 was signed (Confirmed [15][72]; the reading is Inferred).

2.6 Back Orifice, 1998

The Cult of the Dead Cow announced on 21 July 1998 that it would release Back Orifice, written by Sir Dystic, at DEF CON VI on 1 August 1998, as a remote Windows administration tool controlling the file system, registry, passwords, network and processes, with screen and video capture and a built-in HTTP server (Confirmed [17]). cDc's own tool page says the server installs itself, does not appear in the task list, reruns at every startup, runs under a configurable file name, can be attached to another executable, and can log keystrokes (Confirmed [18]). Microsoft's bulletin MS98-010, published 4 August 1998, stated that Back Orifice exposes or exploits no security issue in Windows, Windows NT or BackOffice and must be installed on a machine to work (Confirmed [19], as the vendor's position). Both statements are true at once: Back Orifice needed no flaw, and it showed how easily a full remote-control tool could run unseen on a consumer operating system of the day (Inferred).

Part 3: the worms, viruses and floods

3.1 CIH, 1999

CERT/CC incident note IN-99-03 of 22 April 1999 describes CIH (also Win95.CIH and W95/CIH.1003, the "Chernobyl" virus). It infects executables on Windows 95 and 98; some variants trigger on 26 April 1999, the 13th anniversary of Chernobyl, and others monthly on the 26th or on 26 June; and the payload tries to erase the hard drive and overwrite the system BIOS, which on some machines means replacing the BIOS chip (Confirmed [20]). CIH is the era's clearest destructive payload: disk wipe and firmware corruption in one program (Inferred).

3.2 Melissa, 1999

CERT/CC advisory CA-1999-04, issued 27 March 1999, records reports of the Melissa Word 97 and 2000 macro virus beginning about 2:00 PM GMT-5 on Friday 26 March. It spreads as an email attachment when a user opens the document, lowers macro security settings, mails itself to the first 50 entries of each Outlook address book, and infects the Normal.dot template; its code is VBA (Confirmed [21]). CERT/CC said it was not known to exploit any new vulnerability and that it slowed mail servers at many large sites (Confirmed [21][49]). The control point was user action and macro policy, not patching (Confirmed [21]).

The prosecution is one of the best-documented of the decade. Melissa appeared on thousands of email systems on 26 March 1999, David L. Smith was arrested on 1 April after a tip from AOL, and he pleaded guilty in state and federal court on 9 December 1999 (Confirmed [22]). He admitted building the virus to evade anti-virus software, infect Word 97 and 2000 on Windows 95, 98 and NT, lower macro security and mail itself through Outlook, and first posting it to the alt.sex newsgroup using a stolen AOL account (Confirmed [22]). The federal plea was under 18 U.S.C. 1030(a)(5)(A) and 2, with a maximum of five years and $250,000; the New Jersey plea was to second-degree computer-related theft (Confirmed [22]). On 1 May 2002 Judge Joseph A. Greenaway Jr. sentenced Smith, then 34, of Aberdeen Township, to 20 months, three years of supervised release, a $5,000 fine, 100 hours of community service and a bar on network and Internet use, a significant departure from a guideline range of 46 to 57 months for his cooperation (Confirmed [22]). The investigators credited were the New Jersey State Police High Technology Crime Unit, the FBI and its New Jersey NIPC component, DOJ's CCIPS, DCIS and the Monmouth County Prosecutor, with ICSA.net assisting on damage analysis (Confirmed [22]). The "more than $80 million" damage figure is what Smith acknowledged in his plea agreement, not an independent measurement (Confirmed [22]).

3.3 The DDoS toolkits, 1999 to 2000

Before the commerce sites went down, CERT/CC had already described the tools. CA-1999-17 (28 December 1999) covers TFN2K: client-server control of compromised hosts, IP spoofing, floods and malformed-packet crash attacks, with Mac OS 9 abusable as a traffic amplifier of about 37.5 times (Confirmed [21]). On 3 January 2000, CERT/CC and FedCIRC's CA-2000-01 said tools such as Stacheldraht, TFN and trinoo depend on first compromising hosts through known vulnerabilities, and urged patching and RFC 2267 ingress filtering against spoofing (Confirmed [29]). That advice came five weeks before the February attacks (Confirmed [29]; the interval is computed).

3.4 February 2000: the commerce sites go dark

Yahoo and companion sites, including Yahoo Mail and GeoCities, were unreachable for about three hours on Monday 7 February 2000 after what Yahoo described as a distributed denial-of-service attack on a router (Reported [23]). On Tuesday 8 February, follow-on attacks hit Amazon.com, eBay, Buy.com and CNN Interactive (Reported [24]). On 15 February Wired reported an IRC log showing a 15-year-old Canadian called mafiaboy soliciting others to join in shutting down CNN (Reported [26]).

The primary record is the Attorney General's statement of 19 April 2000. Janet Reno said the February attacks had targeted sites including Yahoo, eBay and CNN.com, and that after joint FBI, DOJ and RCMP work the RCMP had arrested a 15-year-old using the name "mafia boy" in Montreal the previous Saturday, charged over the CNN attack (Confirmed [25]). Wired reported that Mafiaboy, 14 at the time of the attacks, pleaded guilty in January 2001 to 58 charges over attacks that disabled Amazon, eBay, Yahoo and other sites over five days, and that under Canadian law he faced up to two years of juvenile detention against up to ten years for an adult (Reported [27]). The Register reported that Judge Gilles Ouellet in Montreal sentenced him on 12 September 2001 to eight months in youth detention (open custody) plus a year of probation and a small fine, after a guilty plea to 56 counts of mischief to data, naming eBay, Yahoo, Buy.com, Dell, Amazon, CNN and AOL Time Warner as targets (Reported [28]). No primary record of the sentence or of any damage estimate was opened.

3.5 ILOVEYOU, 2000

CERT/CC advisory CA-2000-04 of 4 May 2000 describes the "Love Letter" VBScript worm (subject ILOVEYOU, attachment LOVE-LETTER-FOR-YOU.TXT.VBS). It mails itself to every Outlook address-book entry and spreads over mIRC DCC, through shared files and on USENET. It overwrites script and image files so that recovery may be impossible, hides music files, sets Run registry keys, and tries to fetch a further executable. By 5:00 pm EDT on 8 May, more than 650 sites had reported more than 500,000 affected systems (Confirmed [29]).

The legal aftermath is the lasting part. The Philippines approved Republic Act 8792, the Electronic Commerce Act, on 14 June 2000; its Section 33(a) penalizes hacking and the introduction of computer viruses with a minimum fine of P100,000 and mandatory imprisonment of six months to three years (Confirmed [30]). On 21 August 2000 Philippine authorities dismissed all charges against Onel A. de Guzman, 24, for insufficient evidence; he had been charged with theft and under an access-device fraud law, and the new e-commerce law could not apply because the program was released before it passed (Reported [31]).

3.6 Code Red, 2001

Microsoft's MS01-033, published 18 June 2001, fixed an unchecked buffer in the Index Server and Indexing Service ISAPI extension (idq.dll) that allowed remote code execution as Local System, CVE-2001-0500 (Confirmed [32]). Default Windows 2000 Server installs were vulnerable because IIS 5.0 installs by default, and the patch added proper input checking (Confirmed [32]). CERT VU#952336 records the flaw as public on 18 June 2001 and first published the next day (Confirmed [52]).

CERT/CC's CA-2001-19 of 19 July 2001 reported a self-propagating worm exploiting that overflow over TCP port 80 against random addresses, said two variants may already have affected more than 250,000 hosts, and noted that unpatched Cisco 600-series DSL routers stopped forwarding packets (Confirmed [33]). CA-2001-23 of 26 July describes the date-driven cycle: propagation on days 1 to 19 of the month, a packet flood at an IP address embedded in the code on days 20 to 27, then dormancy; the earlier variant defaced pages on

English-language hosts; at least 280,000 hosts were compromised in the first wave, and more than 250,000 in nine hours on 19 July (Confirmed [33]). CERT/CC says variants had been attacking since about 13 July and expected propagation to resume on 1 August (Confirmed [50]).

CAIDA measured the random-seed Code-Red version 2 beginning about 10:00 UTC on 19 July 2001 and infecting 359,104 hosts in under fourteen hours, with infection rates peaking above 2,000 hosts per minute (Confirmed [34]; Demonstrated [35]). CAIDA's 14 August 2001 patch survey of infected hosts found patch rates from about 66 percent (UK) to about 13 percent (China), 81 percent in EDU, and patching that rose from 32 to 64 percent only after the 1 August resurgence; it concluded that techniques other than host patching are required to mitigate worms (Demonstrated [35]).

3.7 Nimda, 2001

CERT/CC's CA-2001-26 of 18 September 2001 describes Nimda spreading five ways: email (readme.exe), open network shares, compromised websites infecting visiting browsers, scanning for IIS directory-traversal flaws, and the backdoors left by Code Red II and sadmind/IIS (Confirmed [33][50]). It copies itself to IIS servers over TFTP, harvests addresses from the web cache and MAPI mail, modifies web content, writes .eml and .nws copies, shares the C: drive as C$, creates a Guest account added to Administrators, and trojanizes binaries (Confirmed [33]). Nimda combined more propagation paths than any earlier worm in this record, and it reused other worms' backdoors as a path in (Confirmed [33]; the reading is Inferred).

3.8 Klez, 2001 to 2002

F-Secure's description says first Klez infections were found early on 26 October 2001 and Klez.E first on 17 January 2002, and that the worm uses a known Internet Explorer vulnerability to run an email attachment, persists through a Run registry key, and kills the processes of anti-virus software and of other worms (Nimda, Sircam, Funlove and Code Red) (Confirmed [36]). Sophos named Klez the biggest virus of 2002, saying it infected users for seven months, and nine of its top ten 2002 viruses were Windows mass-mailers (Reported [37]).

3.9 Slammer, 2003

Microsoft's MS02-039, published 24 July 2002, fixed buffer overflows in the SQL Server 2000 and MSDE 2000 Resolution Service, CVE-2002-0649, and advised blocking UDP port 1434 at the firewall; its 31 January 2003 revision says the patch protects against SQL Slammer and is superseded by MS02-061 (Confirmed [38]). CERT VU#484891 records the stack overflow and notes that in January 2003 Microsoft recommended MS02-061 instead (Confirmed [53]). NVD lists the weakness for CVE-2002-0649 as CWE-119 (Confirmed [39]).

CERT/CC's CA-2003-04 of 25 January 2003 describes the MS-SQL Server worm (SQLSlammer, W32.Slammer, Sapphire): it sends 376-byte UDP packets to random addresses on port 1434, carries no payload beyond scanning, and caused network degradation across the Internet (Confirmed [40]). CERT/CC said ingress and egress filtering only limit damage from already-infected hosts and do not prevent initial infection (Confirmed [51]). Moore and colleagues report that Slammer began infecting hosts slightly before 05:30 UTC on Saturday 25 January, reached more than 90 percent of vulnerable hosts within ten minutes (at least 75,000 hosts), caused canceled flights, election interference and ATM failures, and spread two orders of magnitude faster than Code Red, whose doubling time was 37 minutes (Confirmed [41] for the infection timing and spread; Reported [41] for the flight, election and ATM impacts the paper relays). CAIDA's analysis gives a

doubling time of about 8.5 seconds in the first minute and a lower bound of 74,856 infected addresses (Demonstrated [42]).

3.10 Weak passwords and Deloder, 2003

CERT/CC's CA-2003-08 of 11 March 2003 reported thousands of Windows 2000 and XP systems compromised through null or weak Administrator passwords over TCP port 445. The tools open backdoors, take commands over IRC and install DDoS agents; the compromises concentrated in home broadband ranges; and W32/Deloder guesses passwords from a preloaded list (Confirmed [40]). This advisory is the quiet bridge between the DDoS tool era and the botnet era: no software flaw, just default exposure and a weak secret on a broadband host (Inferred).

3.11 Blaster, 2003

Microsoft's MS03-026, published 16 July 2003, fixed a buffer overflow in a DCOM RPC interface allowing remote code execution on Windows NT 4.0, 2000, XP and Server 2003, CVE-2003-0352 (Confirmed [43]). The root cause was RPCSS failing to check message inputs, RPCSS ran by default in all Windows versions, and the workarounds blocked RPC ports (Confirmed [43]). CERT VU#568148 lists 16 July as the date public and notes Microsoft was deploying the patch through Windows Update; it advised blocking TCP 135, 139, 445 and 593 and UDP 135, 137, 138 and 445 at the perimeter, while warning that insiders stay exposed (Confirmed [54]).

CERT/CC's CA-2003-20 of 11 August 2003 describes W32/Blaster: it exploits the DCOM RPC flaw over TCP port 135, retrieves its executable from the attacking host and runs it to scan for more victims, includes a TCP SYN flood against windowsupdate.com that CERT/CC confirmed in lab testing, and marks infection with a "windows auto update" Run registry value (Confirmed [40]). CERT/CC advised patching (also available through Windows Update), enabling Internet Connection Firewall or another host packet filter, and blocking RPC ports at the network border (Confirmed [51]).

Jeffrey Lee Parson, 18, of Minneapolis, was arrested on 29 August 2003 on a complaint that he developed and released the B variant, which infected at least 7,000 computers and turned them into drones attacking windowsupdate.com (Confirmed [44]). On 28 January 2005 he was sentenced to 18 months, three years of supervised release and 100 hours of community service for releasing the "teekids" variant on 12 August 2003; he admitted modifying the original worm and adding remote access, and the government calculated more than 48,000 computers infected (Confirmed [45]). The original Blaster author was not identified in any source opened.

3.12 Discrepancies in the record

- **Code Red counts.** CERT/CC gives more than 250,000 hosts in nine hours and at least 280,000 in the first wave; CAIDA measured 359,104 in under fourteen hours; the 2003 National Strategy states 150,000 systems in 14 hours (Confirmed [33][35][75]). The CAIDA count is the measured figure; the Strategy's is the government's stated figure.
- **Code Red patch date.** CAIDA says Microsoft released the patch on 26 June 2001, eight days after eEye's disclosure; the bulletin itself is dated 18 June 2001 (Reported [35]; Confirmed [32]). This study uses the bulletin date.
- **Mafiaboy.** Outlets give 56 counts of mischief to data (The Register) and 58 charges (Wired), and March or April 2000 for the arrest (Reported [28][27]). The Attorney General's 19 April 2000 statement supports an

arrest on the preceding Saturday, 15 April (Confirmed [25]). Wired gives his age at the attacks as 14; DOJ described a 15-year-old at arrest (Reported [27]; Confirmed [25]). Wired's own February 2000 report [26] already called him 15, against 14 in its June 2001 report [27].

- **Citibank.** Britannica gives about $10 million and Lenta.ru more than $12 million (Reported [1][2]).
- **Mitnick's release.** Wired expected release in January 2000; The Register's "released January 2001" conflicts with it and is treated as an error, and The Register says supervised release ran to January 2003 (Reported [7][8]).
- **Nimda.** The National Strategy says Nimda went nationwide in an hour and attacked 86,000 computers (Confirmed [75], as the government's figure); CERT/CC gives no count.

Part 4: the business dimension

4.1 The market

The NASDAQ Composite closed at 743.58 on 3 January 1995, at 5,048.62 on 10 March 2000 (the highest close from then through 2003), and at 1,114.11 on 9 October 2002 (the lowest close in that series of 957 daily rows) (Confirmed [79]). Peak to trough is a fall of about 78 percent, and the 1995 close was roughly one sixth of the peak (Inferred from [79]). The February 2000 denial-of-service attacks came a month before the peak, and Code Red, Nimda and Klez came during the slide, and Slammer three and a half months after the low close (Confirmed for the dates [79][25][33][36][40]; the juxtaposition is Inferred, and no source opened ties the market to the attacks).

4.2 How big e-commerce was

The Census Bureau's quarterly retail e-commerce series begins with the fourth quarter of 1999 (Confirmed [80]). Census release CB-04-26 reported US retail e-commerce of $17.2 billion in the fourth quarter of 2003, 1.9 percent of retail, and $54.9 billion for 2003, up 26.3 percent and 1.6 percent of total retail (1.3 percent in 2002) (Confirmed [81]). The threats in this part hit a sector that was still a small share of retail even at the end of the era (Inferred).

4.3 CD Universe: theft and extortion, 1999 to 2000

eUniverse, owner of CD Universe, disclosed that in late December 1999 a person claiming to hold CD Universe customer information demanded compensation for not posting it online, and that the FBI opened an investigation (Confirmed [82]). On Saturday 8 January 2000 eUniverse learned the data had been posted on the Internet and notified the FBI, which caused the posting site to be shut down the same day (Confirmed [82]). CD Universe had about 300,000 registered customers; eUniverse could not determine when or how data was taken or the extent of the theft, and treated all customers as possibly affected (Confirmed [82]).

The company notified card issuers, emailed customers to monitor their accounts and consider reissue, retained a security firm, discontinued the third-party card-processing software the extortionist claimed was used, and suspended card processing, which delayed shipments and revenue (Confirmed [83]). It warned of loss of confidence in CD Universe and in e-commerce as a whole, and of possible suits by shareholders, customers, its card processor, card issuers and merchants who accepted the stolen cards (Confirmed [82]). It held directors and officers and general liability insurance but could not determine whether either would cover the theft (Confirmed [82]); reading this as the absence of dedicated cyber cover is Inferred. Its 10-K for the

year ended 31 March 2000 repeats the account and says consumer concern over Internet security could impede commerce that requires transmitting card data (Confirmed [84]).

4.4 Egghead.com, 2000 to 2001

Egghead.com's 10-K, filed 2 April 2001, says that in December 2000 the company experienced a security breach of its computer systems by hackers, and that its customer database stored credit card numbers (Confirmed [85]). It reported losses from orders placed with fraudulent card data even when issuers approved payment, because merchants bear the liability for card-not-present fraud without a cardholder signature (Confirmed [85]). It also reported that Visa U.S.A. and its card processor had notified it of a new cardholder information security standard for e-commerce merchants, which it was working to comply with; the program's name and launch year were not confirmed from an opened source (Confirmed [85]). Egghead filed a voluntary Chapter 11 petition on 15 August 2001 to facilitate an asset sale to Fry's Electronics, and the filing does not attribute the bankruptcy to the breach (Confirmed [86]).

4.5 The Russian extortion ring and the "Invita" sting

DOJ sentenced Vasiliy Gorshkov on 4 October 2002 to 36 months, with restitution of nearly $700,000, for crimes against Speakeasy, Nara Bank, Central National Bank of Waco and PayPal. DOJ said the group stole card data from ISPs, e-commerce sites and online banks and often tried to extort victims with threats to expose data or damage systems (Confirmed [87]). The FBI ran an undercover start-up security company, "Invita", in Seattle, and Gorshkov and Alexey Ivanov arrived for a recorded meeting on 10 November 2000 (Confirmed [87]). Ivanov was sentenced on 25 July 2003 to 48 months for conspiracy, intrusion, computer fraud, card fraud, wire fraud and extortion; the group hacked dozens of US computers and extorted victims, and the aggregate loss was found to be about $25 million (Confirmed [88]). The extortion pattern of the CD Universe case, steal the card file and then demand payment for silence, appears here as an organized business (Inferred).

4.6 Spam becomes an industry

Brad Templeton's history dates the earliest documented email spam to a 1978 DEC message, the first USENET use of "spam" for net abuse to Joel Furr in 1993, and the first deliberate mass posting commonly called spam to Canter and Siegel's "Green Card Lottery" on 12 April 1994 (Reported [89]). By 2003 the FTC's "False Claims in Spam" study of about 1,000 messages sampled from more than 11 million found 66 percent had false From, Subject or body content and 33 percent a false From line; investment and business-opportunity, adult and finance offers made up 55 percent; 96 percent of investment and business-opportunity spam showed falsity; and earlier FTC studies had found 86 percent of posted addresses got spam and 63 percent of removal requests were not honored (Confirmed [90]). Congress found in CAN-SPAM that unsolicited commercial email was estimated at over half of all email traffic, up from about 7 percent in 2001 (Confirmed [77]).

4.7 Rules for the money: Safeguards, breach notice and insurance

The FTC Safeguards Rule (16 CFR Part 314) was published on 23 May 2002 and took effect on 23 May 2003, requiring financial institutions under FTC jurisdiction to keep a written information security program (Confirmed [91]). California SB 1386 (Chapter 915, Statutes of 2002), approved 25 September 2002 and operative 1 July 2003, requires notice to California residents whose unencrypted personal information was, or is reasonably believed to have been, acquired in a breach (Confirmed [92]); the common label "first state breach law" was not checked. The National Strategy to Secure Cyberspace noted in February 2003 that some businesses had begun to use cyber risk insurance to transfer risk and support continuity (Confirmed [75]). A GAO blog teaser linked from GAO-21-477 says cyber insurance had been around about 20 years in 2021, which places the market's start near 2000, without naming a first product (Reported [93]). The NAIC's cybersecurity page gives no start date; its earliest market figure is 2020 premiums of about $6.5 billion (Confirmed [94]).

Part 5: the law and policy record

5.1 The Computer Fraud and Abuse Act

18 U.S.C. 1030 was amended by Pub. L. 99-474 (16 October 1986), Pub. L. 103-322 (13 September 1994), Pub. L. 104-294 (11 October 1996), Pub. L. 107-56 (the USA PATRIOT Act, October 2001) and Pub. L. 107-296, section 225(g) (25 November 2002) (Confirmed [69]). Two of those amendments fall inside this era's first three years and two in its last three (Confirmed [69]). Smith's Melissa plea under 1030(a)(5)(A) is the clearest use of the statute against a virus author in this record (Confirmed [22]; Inferred for "clearest").

5.2 Sentences and release conditions

The US sentences in this record run from Parson's 18 months (imposed in 2005) to Ivanov's 48 months (Confirmed [45][88]). Two sentences show courts weighing cooperation and youth: Smith's 20 months against a 46 to 57 month guideline range, and Mafiaboy's eight months of open custody (Confirmed [22]; Reported [28]). The other legacy is supervision. The Ninth Circuit upheld Mitnick's limits on computer and phone access in 1998, and DOJ's 2001 bulletin described his conditions, barring computers, software, modems, cellular phones and any network-capable device without approval, as a model for hacker cases (Confirmed [6][5]). Smith's sentence carried a network and Internet bar of the same kind (Confirmed [22]). The FCC later questioned Mitnick's fitness to renew his amateur radio licence (Reported [8]).

5.3 PDD-63: critical infrastructure, 1998

PDD/NSC-63, "Critical Infrastructure Protection", of 22 May 1998 defined critical infrastructures as physical and cyber-based systems essential to the minimum operations of the economy and government, naming telecommunications, energy, banking and finance, transportation, water and emergency services (Confirmed [72]). It set an initial operating capability by 2000 and full protective capability within five years (Confirmed [72]). It created lead agencies with sector liaison officials and private sector coordinators, a National Coordinator chairing a Critical Infrastructure Coordination Group, a National Infrastructure Assurance Council, and 180-day agency protection plans (Confirmed [72]). It authorized the FBI to expand into a full-scale National Infrastructure Protection Center and encouraged a private-sector Information Sharing and Analysis Center (Confirmed [72]). It preferred market incentives and voluntary participation, with regulation only on material market failure and with care for privacy (Confirmed [72]). The ISAC model that sector defenders use today starts here (Inferred).

5.4 The Budapest Convention, 2001

The Council of Europe Convention on Cybercrime (ETS 185) was done at Budapest on 23 November 2001 in English and French (Confirmed [70]). Its substantive offences are illegal access (Article 2), illegal interception (3), data interference (4), system interference (5), misuse of devices (6), computer-related forgery and fraud (7 and 8), child sexual abuse material (9) and copyright (10) (Confirmed [70]). Article 35 requires each Party to keep a 24/7 point of contact for immediate assistance, including data preservation, and Article 37 lets non-member States be invited to accede with the unanimous consent of the Contracting States (Confirmed [70]). As of 11 November 2026 the Council of Europe lists 84 Parties and 13 signatories or invitees, with a First Protocol (ETS 189) and a Second Protocol (CETS 224); 2026 marks 25 years of the Convention (Confirmed [71]). The entry-into-force date was not checked. The Philippine experience with ILOVEYOU, where the conduct predated the law, is the problem a common set of offences addresses (Inferred from [31][70]).

5.5 DHS, FISMA and the National Strategy, 2002 to 2003

The Homeland Security Act of 2002 (Pub. L. 107-296), approved 25 November 2002, established DHS (Confirmed [73]). Title II created the Information Analysis and Infrastructure Protection directorate and moved into it the FBI's NIPC (except the Computer Investigations and Operations Section), DoD's National Communications System, Commerce's Critical Infrastructure Assurance Office, DOE's NISAC and GSA's FedCIRC (Confirmed [73]). Section 225 is the Cyber Security Enhancement Act of 2002, Title II Subtitle B is the Critical Infrastructure Information Act, and Title X section 1001 is the Federal Information Security Management Act of 2002 (FISMA) (Confirmed [73]). DHS combined all or part of 22 federal departments and agencies and opened on 1 March 2003 (Confirmed [74]).

The National Strategy to Secure Cyberspace of February 2003 set three objectives: prevent cyber attacks against critical infrastructures, reduce national vulnerability, and minimize damage and recovery time (Confirmed [75]). Its five priorities were a National Cyberspace Security Response System, a Threat and Vulnerability Reduction Program, an Awareness and Training Program, Securing Governments' Cyberspace, and National Security and International Cyberspace Security Cooperation (Confirmed [76]). It records DHS's creation, cites the Cyber Security Research and Development Act (Pub. L. 107-305) and describes sector ISACs (Confirmed [75]). The White House archive notes that the President's Critical Infrastructure Protection Board became the National Infrastructure Advisory Council within DHS (Confirmed [76]).

5.6 CAN-SPAM, 2003

The CAN-SPAM Act of 2003 (Pub. L. 108-187) was approved on 16 December 2003 and took effect on 1 January 2004, except section 9 (Confirmed [77]). Section 4 added 18 U.S.C. 1037, whose first prong covers accessing a protected computer without authorization to send commercial email from it; section 5 bars materially false header information; section 7 makes the FTC the principal enforcer; and section 9 required a Do-Not-E-Mail registry plan within six months (Confirmed [77]). The FTC's current compliance guide (edited January 2024) requires truthful headers and subjects, ad disclosure, a postal address and opt-outs honored within 10 business days, with a civil penalty of up to $53,088 per violating email at the current inflation-adjusted figure (Confirmed [78]). The 1037 prong is the statute's recognition that spam had moved onto hijacked computers, the same compromised broadband hosts CA-2003-08 described (Confirmed [77][40]; the link is Inferred).

Part 6: the defender and vulnerability-management view

6.1 CERT/CC as the clearinghouse

CERT/CC has coordinated the disclosure of software vulnerabilities since its inception in 1988, and began as a small group focused on computer incident response; Richard Pethia was founding director of the SEI CERT Division from 1988 to 2016 (Confirmed [46][47]). Its first advisory, CA-1988-01, was issued in December 1988 citing problems or attacks in the past few weeks; linking it to the November 1988 Morris worm is inference, because the advisory does not name the worm (Confirmed [48]; Inferred for the link; the Cuckoo's Egg study and the Five Hacks study carry the 1988 record). Its advisories from 1988 to 2004 are archived by the SEI and are now part of the US-CERT National Cyber Awareness System (Confirmed [49]). Every worm in Part 3 except Klez, whose record here is F-Secure's, has a CERT/CC advisory or incident note as its anchor record (Confirmed [20][21][29][33][40]).

6.2 CVE: one name for one flaw

Mann and Christey of MITRE proposed a Common Vulnerability Enumeration in a paper dated 8 January 1999, motivated by the trouble of integrating vulnerability databases, scanners and intrusion detection tools that each named vulnerabilities differently (Confirmed [58]). The paper was presented at the 2nd Workshop on Research with Security Vulnerability Databases at Purdue on 21 to 22 January 1999 (Confirmed [59]). A working group became the initial 19-member CVE Editorial Board, the original 321 CVE records were created, and the list launched publicly in September 1999 (Confirmed [59]). By December 2000, 29 organizations had declared CVE compatibility for 43 products, and NIST SP 800-51, first released in 2002, recommended that US agencies use CVE (Confirmed [59]). The worm-era CERT/CC advisories still cite candidate numbers (CA-2003-04 cites CAN-2002-0649), a reminder that the list was new (Confirmed [40]). See the library's CVE Reference.

6.3 Full disclosure and the first disclosure norms

The seclists.org Bugtraq archive begins with November 1993 threads, including discussion of CERT Advisory CA-93:17 and requests to share CERT advisories (Demonstrated [60]). RFPolicy 2.0, by rain forest puppy, asked vendors to make contact within five days and keep in contact at least every five days or face public disclosure; version 1 had required contact within two days; the page shows no issue date (Confirmed [61]). In February 2002 Christey of MITRE and Wysopal of @stake submitted "Responsible Vulnerability Disclosure Process" as an IETF Internet-Draft, which expired without IETF endorsement (Confirmed [62]). It proposed a vendor receipt within 7 days, a clear response within 10 days, an attempted resolution within 30 days with stated reasons if missed, notification of vendors sharing the code base, and an optional grace period of up to 30 days before full details are released (Confirmed [63]). Its reference list shows the policies in circulation: RFPolicy 2.0, the Bugtraq FAQ, the NTBugtraq policy, the CERT/CC Vulnerability Disclosure Policy, and the ACROS, NMRC and @stake policies (Confirmed [63]). The Full-Disclosure mailing list archive begins on 9 July 2002 (Demonstrated [65]). CERT/CC's current policy makes reported vulnerabilities public 45 days after the initial report by default; when that rule began was not checked (Confirmed [64]).

6.4 The patch-to-worm gap

A vendor fix existed before each of the three big Microsoft-platform worms. The gap was about one month for Code Red (18 June to 13 to 19 July 2001), about six months for Slammer (24 July 2002 to 25 January 2003) and 26 days for Blaster (16 July to 11 August 2003) (Inferred, computed from [32][50][38][40][43]). Each bulletin's root cause was a missing input check or size limit: MS01-033 and MS03-026 name missing input checks, and MS02-039 says its patch limits input size (Confirmed [32][43][38]). Each also sat on a service that was on by default or widely exposed (Confirmed [32][43]; Inferred for Slammer from [38][40]). CAIDA's patch data shows the reaction pattern: patching rose sharply only after the resurgence (Demonstrated [35]). The same inventory-and-patch race recurs two decades later in the library's Log4Shell study and Exchange study (Inferred pointer).

6.5 What defense looked like

The era's controls were the mail gateway, the scanner, the perimeter and the host firewall. CERT/CC's Melissa advice was to block the virus signature at mail transfer agents, run virus scanners with updated vendor signature files (it listed CA, McAfee, Sophos, Symantec and Trend Micro) and have users disable Word macros (Confirmed [49]). Microsoft's MS01-033 recommended DMZs, minimal services and isolation of web servers from internal networks (Confirmed [32]). Windows XP shipped with a built-in Internet Connection Firewall, which Microsoft presented as bringing business-style firewall protection to consumers; whether it was on by default at original release was not checked (Confirmed [57]). Perimeter port blocking was the standard compensating control, and CERT's own Blaster guidance warned that it leaves insiders exposed (Confirmed [54]).

6.6 Trustworthy Computing and the SDL

Bill Gates emailed all Microsoft full-time employees on Tuesday 15 January 2002 with the subject "Trustworthy computing", naming it the company's highest priority (Reported [66], from Wired's reprint; Microsoft's own copy returned 404). The memo set out availability, security and privacy aims, cited the previous year's terrorist attacks and widely publicized viruses, and directed that when Microsoft must choose between features and security it should choose security, citing Outlook changes against email-borne viruses (Reported [66]). It says the Visual Studio .NET team carried out a security review in December 2001 and that similar reviews would follow in the Windows division (Reported [66]). Microsoft's own pages confirm the initiative launched in January 2002 and that the SDL grew out of it (Confirmed [67]).

Microsoft's SDL paper says the company ran security pushes in early 2002 (threat modeling, code review, security and penetration testing, and team-wide training) on Windows Server 2003 and other products, and introduced the Final Security Review in late 2002 and early 2003 before Windows Server 2003 shipped (Confirmed [68]). Its Secure Windows Initiative team existed well before 2002 and ran both the Windows Server 2003 push and its Final Security Review (Confirmed [68]). Windows Server 2003 was the first operating system release to implement large parts of the SDL, and SQL Server 2000 SP3 and Exchange 2000 SP3 carried security-push results; Microsoft reports fewer post-release bulletins for this software, which is the vendor's own assessment (Confirmed [68]). The SDL paper was presented at ACSAC in Tucson in December 2004, and the SDL became a mandatory part of Microsoft's development process in 2004 (Confirmed [67]).

Microsoft's October 2003 Security Bulletin Summary was published on 14 October 2003 and the November summary on 11 November 2003, both second Tuesdays (Confirmed [55][56]). Neither page says that this began a fixed monthly cycle, so the start date of what the community calls Patch Tuesday is not established by

the sources opened here.

6.7 Lessons that persist

- **Patch cadence is a measurable risk.** The era gives three clean examples of fix-to-outbreak time (Inferred from [32][38][43][40]).
- **Input validation is the root cause behind the bulletins.** MS01-033 and MS03-026 name missing input checks (Confirmed [32][43]). The library's CWE-20 record exists; binding it to these CVEs is this study's reading, not an NVD mapping (Inferred [96]).
- **Default exposure is the multiplier.** IIS on by default, RPCSS on by default, null Administrator passwords (Confirmed [32][43][40]); the library's CWE-1188, CWE-1392 and CWE-521 records name these classes (Inferred [96]).
- **Speed defeats manual response.** Slammer's ten minutes leave no time for a human decision; only controls already in place matter (Confirmed [41]; Inferred).

Part 7: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every id was checked against the live ATT&CK page or the library's data files on 11 November 2026, and every library page linked below exists in the `mitre/` tree (Confirmed [95][96]). The events predate ATT&CK by more than a decade, so every mapping is this study's retrospective reading of the CERT/CC, Microsoft, DOJ, cDc and Kaspersky records (Inferred). No event in this study touches industrial control systems in the verified record, so there is no ATT&CK for ICS table.

ATT&CK Enterprise techniques

Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment. T1562 and T1562.001 are revoked in v20.0 and map to T1685 Disable or Modify Tools through the library's `data/attack/superseded_by.jsonl` (Confirmed [96]). Library sub-technique pages use a dash in the file name (`T1566-001.md`).

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1566.001	Spearphishing Attachment	Initial Access	Melissa as an email attachment (CA-1999-04, 27 Mar 1999); Love Letter (CA-2000-04, 4 May 2000)	[21][29][95]
T1204.002	Malicious File	Execution	Melissa needs a user to open the document (27 Mar 1999); Love Letter attachment (4 May 2000); Nimda's readme.exe (CA-2001-26, 18 Sep 2001)	[21][29][33][95]
T1059.005	Visual Basic	Execution	Love Letter VBScript (4 May 2000); Melissa VBA macro (27 Mar 1999)	[29][21][95]
T1137.001	Office Template Macros	Persistence	Melissa infects the Normal.dot template (27 Mar 1999)	[21][95]
T1685	Disable or Modify Tools	Defense Impairment	Klez kills anti-virus processes (F-Secure, Oct 2001); Melissa lowers macro security (Inferred id choice); reported under revoked T1562.001 in earlier ATT&CK versions	[36][21][96]

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1547.001	Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	Love Letter Run keys (4 May 2000); Klez Run key (Oct 2001); Blaster "windows auto update" Run value (CA-2003-20, 11 Aug 2003)	[29][36][40][96]
T1105	Ingress Tool Transfer	Command and Control	Love Letter fetches a further executable (4 May 2000); Nimda copies itself over TFTP (18 Sep 2001); Blaster retrieves its executable from the attacking host (11 Aug 2003)	[29][33][40][96]
T1485	Data Destruction	Impact	Love Letter overwrites files so recovery may be impossible (4 May 2000)	[29][95]
T1561.001	Disk Content Wipe	Impact	CIH tries to erase the hard drive (IN-99-03, 22 Apr 1999)	[20][96]
T1495	Firmware Corruption	Impact	CIH overwrites the system BIOS (IN-99-03)	[20][96]
T1190	Exploit Public-Facing Application	Initial Access	Code Red on IIS (CA-2001-19, 19 Jul 2001); Nimda's IIS directory-traversal scanning (18 Sep 2001); Slammer on the SQL Resolution Service (CA-2003-04, 25 Jan 2003); Solar Sunrise's exploitation of a known OS flaw (Reported profile, Feb 1998)	[33][40][10][95]
T1210	Exploitation of Remote Services	Lateral Movement	Blaster over DCOM RPC (11 Aug 2003); worm-to-worm spread of Code Red, Nimda and Slammer	[40][33][95]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	Nimda's open network shares (18 Sep 2001); weak-password compromises over TCP 445 (CA-2003-08, 11 Mar 2003)	[33][40][95]
T1080	Taint Shared Content	Lateral Movement	Nimda writes copies to shares and modifies web content (18 Sep 2001)	[33][96]
T1189	Drive-by Compromise	Initial Access	Nimda's compromised websites infect browsers (18 Sep 2001)	[33][96]
T1203	Exploitation for Client Execution	Execution	Nimda via browsers (18 Sep 2001); Klez's known Internet Explorer vulnerability (Oct 2001; Inferred id choice)	[33][36][96]
T1136.001	Local Account	Persistence	Nimda creates a Guest account (18 Sep 2001)	[33][96]
T1098	Account Manipulation	Persistence, Privilege Escalation	Nimda adds Guest to Administrators (18 Sep 2001)	[33][96]
T1491.002	External Defacement	Impact	Code Red's earlier variant defaces English-language hosts (CA-2001-23, 26 Jul 2001)	[33][95]
T1498	Network Denial of Service	Impact	The February 2000 attacks on commerce sites; Slammer's network degradation as a side effect (25 Jan 2003); DDoS agents in CA-2003-08	[25][40][95]
T1498.001	Direct Network Flood	Impact	TFN2K floods (CA-1999-17, 28 Dec 1999); Code Red's flood on days 20 to 27 (26 Jul 2001); Blaster's SYN flood against windowsupdate.com (11 Aug 2003)	[21][33][40][95]

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1498.002	Reflection Amplification	Impact	Mac OS 9 as a traffic amplifier of about 37.5 times (CA-1999-17)	[21][95]
T1499	Endpoint Denial of Service	Impact	TFN2K malformed-packet crash attacks (CA-1999-17)	[21][95]
T1499.001	OS Exhaustion Flood	Impact	Blaster's TCP SYN flood (11 Aug 2003)	[40][96]
T1584.005	Botnet	Resource Development	DoS tools installed on compromised hosts (CA-2000-01, 3 Jan 2000); IRC-controlled DDoS agents (CA-2003-08)	[29][40][96]
T1219	Remote Access Tools	Command and Control	Back Orifice (cDc, 21 Jul and 1 Aug 1998)	[17][18][96]
T1056.001	Keylogging	Collection, Credential Access	Back Orifice keystroke logging	[18][96]
T1113	Screen Capture	Collection	Back Orifice screen capture	[17][96]
T1125	Video Capture	Collection	Back Orifice video capture	[17][96]
T1595.002	Vulnerability Scanning	Reconnaissance	Solar Sunrise probing for a known OS vulnerability (Feb 1998; Reported profile)	[10][96]
T1040	Network Sniffing	Credential Access, Discovery	Solar Sunrise sniffer implants (Reported profile); Mitnick's admitted use of sniffers (1999 plea; home study)	[10][3][96]
T1090.003	Multi-hop Proxy	Command and Control	Moonlight Maze relays through a series of hacked servers (1998 to 1999)	[13][96]
T1584.004	Server	Resource Development	Moonlight Maze's hacked relay servers (1998 to 1999)	[13][96]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Mitnick's theft of passwords (DOJ bulletin, Mar 2001); the home study carries the full Mitnick mapping	[5][96]
T1078.001	Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Null or weak Administrator passwords (CA-2003-08, 11 Mar 2003)	[40][95]
T1110.001	Password Guessing	Credential Access	W32/Deloder guesses from a preloaded list (CA-2003-08)	[40][95]

Levin's Citibank transfers carry no technique: no primary record of the method was opened (Part 2.1). The Mitnick record is mapped in full in the home study's layer; this table carries only the two ids the summary paragraph touches.

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to this study	Source
Turla	G0010	Kaspersky and King's College London trace Penquin Turla to the LOKI2 code base and call a Moonlight Maze link premature; ATT&CK's page does not mention Moonlight Maze	[13][14]
Penquin	S0587	The backdoor at the centre of that lineage research; ATT&CK describes it as used by Turla against Linux since at least 2014, with no Moonlight Maze text	[13][14]

No ATT&CK group, software or campaign object exists for Melissa, ILOVEYOU, CIH, Code Red, Nimda, Klez, Slammer, Blaster, Back Orifice, the TFN2K and trinoo tools, Solar Sunrise or Moonlight Maze in the library's ATT&CK v20.0 data, and they are left unlinked (Confirmed [96]).

CWE and CAPEC

Weakness or pattern	Name	Who assigns it	Use here	Source
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	NVD, for CVE-2002-0649 (Slammer)	The only NVD CWE mapping among the three worm CVEs	[39]
NVD-CWE-Other	(no specific CWE)	NVD, for CVE-2001-0500 (Code Red) and CVE-2003-0352 (Blaster), and also for CVE-2001-0154 (Internet Explorer HTML e-mail executing attachments with an unusual MIME type) and CVE-2000-0884 (IIS "Web Server Folder Traversal" via Unicode-encoded URLs)	No CWE can be cited as an NVD mapping for these	[39]
CWE-20	Improper Input Validation	Not on the NVD records; present in the library's data	MS01-033 and MS03-026 name missing input checks (Inferred binding)	[32][43][96]
CWE-1188	Initialization of a Resource with an Insecure Default	Not on the NVD records; present in the library's data	IIS 5.0 and RPCSS on by default (Inferred binding)	[32][43][96]
CWE-1392	Use of Default Credentials	Not on the NVD records; present in the library's data	Null Administrator passwords in CA-2003-08 (Inferred binding)	[40][96]
CWE-521	Weak Password Requirements	Not on the NVD records; present in the library's data	Weak Administrator passwords in CA-2003-08 (Inferred binding)	[40][96]
CAPEC-100	Overflow Buffers	No CAPEC id appears on the NVD records opened; the library's CWE-119 record lists CAPEC-100 among its related patterns	The buffer overflows behind Code Red, Slammer and Blaster (Inferred binding)	[39][96]

NVD's CVSS v2 base scores are 10.0 for CVE-2001-0500 and 7.5 for both CVE-2002-0649 and CVE-2003-0352 (Confirmed [39]). The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mapping to this study's techniques in `technique_to_d3fend.json`	Era guidance it matches	Source
Network Traffic Filtering	D3-NTF	T1210, T1190	Blocking RPC and SMB ports at the perimeter (VU#568148); blocking UDP 1434 (MS02-039)	[96][54][38]
Inbound Traffic Filtering	D3-ITF	T1190	RFC 2267 ingress filtering (CA-2000-01); border filtering (CA-2003-04), which CERT/CC said limits spread from infected hosts but does not prevent initial infection [51]	[96][29][51]
Segment Address Offset Randomization	D3-SAOR	T1210, T1190	A modern memory-safety defense against the era's stack overflows (Inferred pairing)	[96]
Stack Frame Canary Validation	D3-SFCV	T1210	Same (Inferred pairing)	[96]
Executable Allowlisting	D3-EAL	T1204.002, T1137.001	Stopping attachments and macros from running (Inferred pairing with CA-1999-04)	[96][49]
File Analysis	D3-FA	T1204.002, T1137.001	Signature scanning of attachments (CA-1999-04)	[96][49]
Email Filtering	D3-EF	T1566.001	Blocking the Melissa signature at mail transfer agents (CA-1999-04)	[96][49]
Change Default Password	D3-CDP	T1078.001, T1110.001	Null and weak Administrator passwords (CA-2003-08)	[96][40]
Strong Password Policy	D3-SPP	T1110.001	Same	[96][40]

The mappings in the third column are the library's data (Confirmed [96]); pairing each countermeasure with the era's advice is this study's reading (Inferred). The library's D3FEND pages are listed in the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/dotcom-era-cyber-events.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of the record behind it: 100 where a Confirmed primary record (a CERT/CC advisory or incident note, a Microsoft bulletin, a DOJ record, cDc's own pages or Kaspersky's own findings) describes the behavior, 60 where the behavior is known only from a Reported source (the Solar Sunrise profile), and 40 where the id choice itself stretches the record (Mitnick's Valid Accounts). Each entry's comment names the source numbers above.

Cross-cutting themes

- **The fix was usually already out.** Code Red, Slammer and Blaster all followed a Microsoft bulletin (Confirmed [32][38][43]); Melissa exploited no new vulnerability and the 2003 password compromises relied on null or weak Administrator passwords rather than a software flaw (Confirmed [21][40]). The decade's lesson for vulnerability management is less "find the zero-day" than "close the known hole on everything that listens" (Inferred). See the Vulnerability Management Reference and the Vulnerability Prioritization Reference.
- **Defaults are policy.** IIS on by default, RPCSS on by default and blank Administrator passwords turned single flaws into Internet-wide events (Confirmed [32][43][40]). See Windows Hardening.
- **Speed outruns people.** From Code Red's 37-minute doubling time to Slammer's 8.5 seconds, the response window shrank to nothing in eighteen months (Confirmed [41]; Demonstrated [42]). CAIDA drew the conclusion at the time: host patching alone does not mitigate worms (Demonstrated [35]).
- **The community built its own infrastructure.** Bugtraq, RFPolicy and the Christey and Wysopal draft came from practitioners; CVE came from MITRE researchers and was recommended to US agencies in NIST SP 800-51 in 2002; CERT/CC coordinated disclosure throughout (Confirmed [60][61][62][58][59][46]; the reading is Inferred). See the CVE Reference.
- **Teenagers made the headlines; the long campaign was quieter.** The FBI searched two California teenagers' homes over Solar Sunrise despite its timing, the attackers are reported as three teenagers, and Mafiaboy was 15 at arrest, while Moonlight Maze ran for years and is still only partly documented (Confirmed [9][25][13]; Reported [10] for the attackers' ages). See Threat Actors.
- **Commerce learned it carried the fraud.** Card-not-present liability, extortion over stolen card files and the question of insurance cover all appear in the SEC filings of 2000 and 2001 (Confirmed [85][82]). See the Fraud Framework Reference.
- **Law followed the incident.** RA 8792 came weeks after ILOVEYOU and could not reach it, and CAN-SPAM and SB 1386 came after years of spam and breaches (Confirmed [30][77][92]; Reported [31]). See the Regulatory Landscape Reference.

What is overstated and what is understated

- **Overstated: the damage figures.** Melissa's $80 million is Smith's admission in a plea agreement, Code Red's $2.6 billion is a third-party estimate CAIDA repeats rather than measures, and the Mafiaboy estimates run from US$1.7 billion (estimates released after the attacks, as Wired relays) and GBP 1.1 billion (The Register) down to the Crown prosecutor's statement in court that the figure was probably closer to about $7.5 million, all unaudited and inconsistent (Confirmed [22]; Reported [35][27][28]). None is a measured loss.
- **Overstated: Solar Sunrise as a state attack.** It arrived while the US prepared for possible action against Iraq, but DOJ said there was no indication of an organized military or state-sponsored campaign, and the attackers were teenagers (Confirmed [9]; Reported [10]).
- **Overstated: Moonlight Maze as Turla.** The researchers who traced the code call the link premature and circumstantial, and ATT&CK's Turla and Penquin pages do not mention Moonlight Maze (Reported [13]; Confirmed [14]).

- **Overstated: Levin as the man who broke in.** Britannica names dozens of confederates, and the participant account Lenta.ru summarized says others reached Citibank's network first and the access was later used by Levin (Reported [1][2]).
- **Overstated: Back Orifice as a Windows vulnerability.** Microsoft's position, correct on its own terms, is that it exploited no flaw and had to be installed (Confirmed [19]).
- **Overstated: the breach as the cause of Egghead's bankruptcy.** The Chapter 11 filing does not attribute it to the December 2000 breach (Confirmed [86]).
- **Understated: patching and defaults as the root cause.** None of Code Red, Slammer or Blaster used an unpatched flaw, and Melissa used no new vulnerability (Confirmed [32][38][43][21]; Inferred for the framing).
- **Understated: Moonlight Maze itself.** It began around 1996 against the Pentagon, NASA and the Department of Energy among others, years before the worms, and the public evidence is one administrator's preserved logs (Reported [13]).
- **Understated: ILOVEYOU's legal effect.** A statute with hacking and virus penalties was approved six weeks after the worm, and the prosecution was dismissed for insufficient evidence under older theft and access-device charges, because the new law could not reach back (Confirmed [30]; Reported [31]; the link between worm and statute is Inferred).
- **Understated: the government's own counts.** The National Strategy's 150,000 Code Red systems is well under CAIDA's measured 359,104, so policy documents of the time understated the scale (Confirmed [75]; Demonstrated [35]; Inferred).

Sources

All sources were opened on 11 November 2026. Sources are grouped by topic: the intrusions [1] to [19], the worms and floods [20] to [45], the defense record [46] to [68], law and policy [69] to [78], the business dimension [79] to [94], and the MITRE record and library data [95] and [96]. Grades apply to the source as used here. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings and the ftc.gov and gao.gov pages); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	Encyclopaedia Britannica, Vladimir Levin	britannica.com/biography/Vladimir-Levin	2026-11-11	Reported
2	Lenta.ru, article on Levin and the Citibank case, 2 Nov 2005	lenta.ru/articles/2005/11/02/levin/	2026-11-11	Reported
3	US DOJ (cybercrime.gov, UNT web archive copy), Mitnick sentencing release, 1999	webarchive.library.unt.edu/eot2008/.../cybercrime.gov/mitnick.htm	2026-11-11	Confirmed
4	US DOJ, Mitnick arrest release, 15 Feb 1995	justice.gov/archive/opa/pr/Pre_96/February95/89.txt.html	2026-11-11	Confirmed
5	US DOJ, United States Attorneys' Bulletin, March 2001 (Mitnick record and release conditions)	justice.gov/.../usab4902.pdf	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
6	US Court of Appeals, Ninth Circuit, United States v. Mitnick, No. 97-50365, 20 May 1998 (OpenJurist)	openjurist.org/145/f3d/1342/united-states-of-america-v-mitnick	2026-11-11	Confirmed
7	Wired, Life not kosher for Mitnick, August 1999	wired.com/1999/08/life-not-kosher-for-mitnick/	2026-11-11	Reported
8	The Register, on the FCC and Mitnick's amateur radio licence, 3 Jan 2002	theregister.com/2002/01/03/us_to_yank_kevin_mitnicks/	2026-11-11	Reported
9	US DOJ, release 98-125, Israeli citizen arrested (Tenenbaum), 18 Mar 1998	justice.gov/archive/opa/pr/1998/March/125.htm.html	2026-11-11	Confirmed
10	GlobalSecurity.org, Solar Sunrise	globalsecurity.org/military/ops/solar-sunrise.htm	2026-11-11	Reported
11	Los Angeles Times, article on Tenenbaum in Israel, 27 Apr 1998	latimes.com/archives/la-xpm-1998-apr-27-mn-43491-story.html	2026-11-11	Reported
12	The Register, Solar Sunrise hacker "Analyzer" escapes jail, 15 Jun 2001	theregister.com/offbeat/2001/06/15/solar-sunrise-hacker-analyzer-escapes-jail/941723	2026-11-11	Reported
13	Kaspersky GReAT and King's College London, Penquin's Moonlit Maze, 3 Apr 2017	securelist.com/penquins-moonlit-maze/77883/	2026-11-11	Confirmed for the researchers' own findings; Reported for attribution and relayed remarks
14	MITRE ATT&CK, G0010 Turla and S0587 Penquin	attack.mitre.org/groups/G0010/ and attack.mitre.org/software/S0587/	2026-11-11	Confirmed
15	US Senate Committee on Governmental Affairs, Weak Computer Security in Government: Is the Public at Risk?, 19 May 1998	hsgac.senate.gov/hearings/weak-computer-security-in-government-is-the-public-at-risk/	2026-11-11	Confirmed
16	Sen. Fred Thompson, prepared statement, 19 May 1998	hsgac.senate.gov/.../thompson051998.pdf	2026-11-11	Confirmed
17	Cult of the Dead Cow, Back Orifice press release, 21 Jul 1998	cultdeadcow.com/news/back_orifice.html	2026-11-11	Confirmed
18	Cult of the Dead Cow, Back Orifice tool page	cultdeadcow.com/tools/bo.html	2026-11-11	Confirmed
19	Microsoft Security Bulletin MS98-010, Information on the Back Orifice program, 4 Aug 1998	learn.microsoft.com/.../1998/ms98-010	2026-11-11	Confirmed (vendor position)
20	CERT/CC, 1999 Incident Notes (SEI), including IN-99-03 CIH	sei.cmu.edu/documents/520/1999_019_001_496442.pdf	2026-11-11	Confirmed
21	CERT/CC, 1999 Advisories (SEI), including CA-1999-04 Melissa and CA-1999-17 Denial-of-Service Tools	sei.cmu.edu/documents/506/1999_019_001_496184.pdf	2026-11-11	Confirmed
22	US DOJ, District of New Jersey, Melissa creator sentenced, 1 May 2002	justice.gov/archive/criminal/cybercrime/press-releases/2002/melissaSent.htm	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
23	CNN (IDG), Yahoo assault, 8 Feb 2000	cnn.com/2000/TECH/computing/02/08/yahoo.assault.idg/	2026-11-11	Reported
24	CNN, Cyber attacks, 9 Feb 2000	cnn.com/2000/TECH/computing/02/09/cyber.attacks.01/	2026-11-11	Reported
25	US DOJ, Attorney General Reno statement on the February denial-of-service arrest, 19 Apr 2000	justice.gov/archive/opa/pr/2000/April/217ag.htm	2026-11-11	Confirmed
26	Wired, Hot on the trail of mafiaboy, 15 Feb 2000	wired.com/2000/02/hot-on-the-trail-of-mafiaboy/	2026-11-11	Reported
27	Wired, Prison urged for Mafiaboy, June 2001	wired.com/2001/06/prison-urged-for-mafiaboy/	2026-11-11	Reported
28	The Register, Mafiaboy given eight months, 13 Sep 2001 (also at the theregister.co.uk address)	theregister.com/security/2001/09/13/mafiaboy-given-eight-months/970005 and theregister.co.uk/2001/09/13/mafiaboy_given_eight_months	2026-11-11	Reported
29	CERT/CC, 2000 Advisories (SEI), including CA-2000-01 Denial-of-Service Developments and CA-2000-04 Love Letter	sei.cmu.edu/documents/507/2000_019_001_496188.pdf	2026-11-11	Confirmed
30	Republic of the Philippines, Republic Act No. 8792, Electronic Commerce Act, 14 Jun 2000 (Lawphil)	lawphil.net/statutes/repacts/ra2000/ra_8792_2000.html	2026-11-11	Confirmed
31	New York Times, charges dropped in the ILOVEYOU case, 22 Aug 2000	archive.nytimes.com/.../22virus.html	2026-11-11	Reported
32	Microsoft Security Bulletin MS01-033, Index Server ISAPI extension, 18 Jun 2001	learn.microsoft.com/.../2001/ms01-033	2026-11-11	Confirmed
33	CERT/CC, 2001 Advisories (SEI), including CA-2001-19 and CA-2001-23 Code Red and CA-2001-26 Nimda	sei.cmu.edu/documents/508/2001_019_001_496192.pdf	2026-11-11	Confirmed
34	CAIDA, Code-Red worms archive page	caida.org/archive/code-red/	2026-11-11	Confirmed
35	CAIDA, Code-Red worm case study paper, 2002	caida.org/catalog/papers/2002_codered/codered.pdf	2026-11-11	Demonstrated for CAIDA's measurements; Reported for the relayed cost and patch-date figures
36	F-Secure, Klez description	f-secure.com/v-descs/klez	2026-11-11	Confirmed
37	InformationWeek, Klez virus tabbed as year's biggest, 5 Dec 2002	informationweek.com/.../klez-virus-tabbed-as-year-s-biggest	2026-11-11	Reported
38	Microsoft Security Bulletin MS02-039, SQL Server Resolution Service, 24 Jul 2002, revised 31 Jan 2003	learn.microsoft.com/.../2002/ms02-039	2026-11-11	Confirmed
39	NIST NVD, CVE API records for CVE-2002-0649, CVE-2001-0500, CVE-2003-0352, CVE-2001-0154 and CVE-2000-0884	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2002-0649 (and the same path for each id)	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
40	CERT/CC, 2003 Advisories (SEI), including CA-2003-04 MS-SQL Server Worm, CA-2003-08 and CA-2003-20 W32/Blaster	sei.cmu.edu/documents/510/2003_019_001_496200.pdf	2026-11-11	Confirmed
41	Moore et al., Slammer worm analysis, IEEE Security and Privacy, 2003 (UCSD copy)	cseweb.ucsd.edu/~savage/papers/IEEESP03.pdf	2026-11-11	Confirmed for the authors' measurements; Reported for relayed impacts
42	CAIDA, Sapphire/Slammer worm analysis, 2003	caida.org/catalog/papers/2003_sapphire/	2026-11-11	Demonstrated
43	Microsoft Security Bulletin MS03-026, DCOM RPC interface buffer overflow, 16 Jul 2003	learn.microsoft.com/.../2003/ms03-026	2026-11-11	Confirmed
44	US DOJ, Parson arrest release, 29 Aug 2003	justice.gov/archive/criminal/cybercrime/press-releases/2003/parsonArrest.htm	2026-11-11	Confirmed
45	US DOJ, Parson sentencing release, 28 Jan 2005	justice.gov/archive/criminal/cybercrime/press-releases/2005/parsonSent.htm	2026-11-11	Confirmed
46	CERT/CC, The CERT Guide to Coordinated Vulnerability Disclosure	certcc.github.io/CERT-Guide-to-CVD/	2026-11-11	Confirmed
47	SEI, CERT Division page	sei.cmu.edu/about/divisions/cert/index.cfm	2026-11-11	Confirmed
48	SEI, 1988 CERT Advisories	insights.sei.cmu.edu/library/1988-cert-advisories/	2026-11-11	Confirmed
49	SEI, 1999 CERT Advisories (library page)	insights.sei.cmu.edu/library/1999-cert-advisories/	2026-11-11	Confirmed
50	SEI, 2001 CERT Advisories (library page)	insights.sei.cmu.edu/library/2001-cert-advisories/	2026-11-11	Confirmed
51	SEI, 2003 CERT Advisories (library page)	insights.sei.cmu.edu/library/2003-cert-advisories/	2026-11-11	Confirmed
52	CERT/CC Vulnerability Note VU#952336	kb.cert.org/vuls/id/952336	2026-11-11	Confirmed
53	CERT/CC Vulnerability Note VU#484891	kb.cert.org/vuls/id/484891	2026-11-11	Confirmed
54	CERT/CC Vulnerability Note VU#568148	kb.cert.org/vuls/id/568148	2026-11-11	Confirmed
55	Microsoft Security Bulletin Summary, October 2003	learn.microsoft.com/.../2003/ms03-oct	2026-11-11	Confirmed
56	Microsoft Security Bulletin Summary, November 2003	learn.microsoft.com/.../2003/ms03-nov	2026-11-11	Confirmed
57	Microsoft, Windows XP Internet Connection Firewall documentation	learn.microsoft.com/.../windows-xp/bb457059(v=technet.10)	2026-11-11	Confirmed
58	Mann and Christey (MITRE), Towards a Common Enumeration of Vulnerabilities, 8 Jan 1999	cve.org/Resources/General/Towards-a-Common-Enumeration-of-Vulnerabilities.pdf	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
59	CVE Program, website source for the History page	github.com/CVEProject/cve-website/.../History.vue	2026-11-11	Confirmed
60	seclists.org, Bugtraq archive, November 1993	seclists.org/bugtraq/1993/Nov/	2026-11-11	Demonstrated
61	rain forest puppy, RFPolicy 2.0	wiretrip.net/rfp/policy.html	2026-11-11	Confirmed
62	IETF Datatracker, draft-christey-wysopal-vuln-disclosure	datatracker.ietf.org/doc/draft-christey-wysopal-vuln-disclosure/	2026-11-11	Confirmed
63	Christey and Wysopal, Responsible Vulnerability Disclosure Process, Internet-Draft -00, February 2002	ietf.org/archive/id/draft-christey-wysopal-vuln-disclosure-00.txt	2026-11-11	Confirmed
64	CERT/CC, Vulnerability Disclosure Policy	certcc.github.io/certcc_disclosure_policy/	2026-11-11	Confirmed
65	seclists.org, Full-Disclosure archive, July 2002	seclists.org/fulldisclosure/2002/Jul/	2026-11-11	Demonstrated
66	Wired, reprint of Bill Gates's Trustworthy Computing memo, January 2002	wired.com/2002/01/bill-gates-trustworthy-computing/	2026-11-11	Reported
67	Microsoft, About the Security Development Lifecycle	microsoft.com/en-us/securityengineering/sdl/about	2026-11-11	Confirmed
68	Microsoft, The Trustworthy Computing Security Development Lifecycle (MSDN paper)	learn.microsoft.com/en-us/previous-versions/ms995349(v=msdn.10)	2026-11-11	Confirmed
69	Cornell Legal Information Institute, 18 U.S.C. 1030 and its amendment notes	law.cornell.edu/uscode/text/18/1030	2026-11-11	Confirmed
70	Council of Europe, Convention on Cybercrime, ETS 185, 23 Nov 2001	rm.coe.int/1680081561	2026-11-11	Confirmed
71	Council of Europe, The Budapest Convention page	coe.int/en/web/cybercrime/the-budapest-convention	2026-11-11	Confirmed
72	PDD/NSC-63, Critical Infrastructure Protection, 22 May 1998 (FAS)	irp.fas.org/offdocs/pdd/pdd-63.htm	2026-11-11	Confirmed
73	Homeland Security Act of 2002, Pub. L. 107-296	govinfo.gov/content/pkg/PLAW-107publ296/pdf/PLAW-107publ296.pdf	2026-11-11	Confirmed
74	DHS, Creation of the Department of Homeland Security	dhs.gov/creation-department-homeland-security	2026-11-11	Confirmed
75	The National Strategy to Secure Cyberspace, February 2003 (CISA copy)	cisa.gov/sites/default/files/publications/cyberspace_strategy.pdf	2026-11-11	Confirmed
76	White House archive, President's Critical Infrastructure Protection Board page	georgewbush-whitehouse.archives.gov/pcipb/	2026-11-11	Confirmed
77	CAN-SPAM Act of 2003, Pub. L. 108-187	govinfo.gov/content/pkg/PLAW-108publ187/pdf/PLAW-108publ187.pdf and the HTML text	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
78	FTC, CAN-SPAM Act: A Compliance Guide for Business (edited January 2024)	https://www.ftc.gov/business-guidance/resources/can-spam-act-compliance-guide-business	2026-11-11	Confirmed
79	Federal Reserve Bank of St. Louis (FRED), NASDAQ Composite Index series NASDAQCOM	fred.stlouisfed.org/graph/fredgraph.csv?id=NASDAQCOM&cosd=2000-03-10&coed=2003-12-31 (also the 1995-01-03 to 1995-01-05 and 2000-03-06 to 2000-03-14 ranges)	2026-11-11	Confirmed
80	US Census Bureau, Quarterly Retail E-Commerce historic releases	census.gov/retail/ecommerce/historic_releases.html	2026-11-11	Confirmed
81	US Census Bureau, release CB-04-26, 4th quarter 2003 retail e-commerce, 23 Feb 2004	www2.census.gov/retail/releases/historical/ecomm/03q4.pdf	2026-11-11	Confirmed
82	SEC EDGAR, eUniverse filing 0000950117-00-000306, February 2000	https://www.sec.gov/Archives/edgar/data/1088244/0000950117-00-000306.txt	2026-11-11	Confirmed
83	SEC EDGAR, eUniverse filing 0000950117-00-000084, January 2000	https://www.sec.gov/Archives/edgar/data/1088244/0000950117-00-000084.txt	2026-11-11	Confirmed
84	SEC EDGAR, eUniverse 10-K for the fiscal year ended 31 Mar 2000	https://www.sec.gov/Archives/edgar/data/1088244/0000950117-00-001749.txt	2026-11-11	Confirmed
85	SEC EDGAR, Egghead.com 10-K, filed 2 Apr 2001	https://www.sec.gov/Archives/edgar/data/1026506/000102650601500003/body10k.htm	2026-11-11	Confirmed
86	SEC EDGAR, Egghead.com 8-K on the Chapter 11 petition, August 2001	https://www.sec.gov/Archives/edgar/data/1026506/000102650601500007/body8k.htm	2026-11-11	Confirmed
87	US DOJ, Gorshkov sentencing release, 4 Oct 2002	justice.gov/archive/criminal/cybercrime/press-releases/2002/gorshkovSent.htm	2026-11-11	Confirmed
88	US DOJ, Ivanov sentencing release, 25 Jul 2003	justice.gov/archive/criminal/cybercrime/press-releases/2003/ivanovSent.htm	2026-11-11	Confirmed
89	Brad Templeton, on the origin of the term "spam"	templetons.com/brad/spamterm.html	2026-11-11	Reported
90	FTC, False Claims in Spam, 30 Apr 2003	https://www.ftc.gov/sites/default/files/documents/reports/false-claims-spam/030429spamreport_0.pdf	2026-11-11	Confirmed
91	Federal Register, FTC Safeguards Rule (16 CFR Part 314), 23 May 2002	govinfo.gov/content/pkg/FR-2002-05-23/html/02-12952.htm	2026-11-11	Confirmed
92	California SB 1386, chaptered text (Chapter 915, Statutes of 2002)	leginfo.ca.gov/.../sb_1386_bill_20020926_chaptered.html	2026-11-11	Confirmed
93	US GAO, GAO-21-477 product page, 20 May 2021 (linked blog teaser)	https://www.gao.gov/products/gao-21-477	2026-11-11	Reported

#	Source	URL	Opened	Grade
94	NAIC, Cybersecurity insurance topic page	content.naic.org/insurance-topics/cybersecurity	2026-11-11	Confirmed
95	MITRE ATT&CK v20, technique pages T1210, T1021, T1137.001, T1204.002, T1059.005, T1498, T1190, T1078.001 and T1566.001, with T1491.002, T1485 and T1110.001	attack.mitre.org/techniques/T1210/ (and the same path for each id)	2026-11-11	Confirmed
96	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `data/attack/superseded_by.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl`, the `mitre/` tree and `case-studies/`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data and the mitre/techniques tree	2026-11-11	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents
- Vulnerability Management Reference, Vulnerability Prioritization Reference, Vulnerability Root Causes
- Email Security Reference, Windows Hardening Reference, Network Security Architecture, Secure Coding Reference
- Fraud Framework Reference, Regulatory Landscape Reference, Incident Response Reference
- Related studies: The Cuckoo's Egg Intrusion, 1986, Kevin Mitnick, Five Hacks and Why They Worked, Cybercrime and Hacktivism in Four Books, Russia-Attributed Threat Actors, Log4Shell, Exchange 2021, Case study timeline
- Groups and software: G0010 Turla, S0587 Penquin
- Techniques: T1190 Exploit Public-Facing Application, T1210 Exploitation of Remote Services, T1566.001 Spearphishing Attachment, T1204.002 Malicious File, T1059.005 Visual Basic, T1137.001 Office Template Macros, T1498 Network Denial of Service, T1495 Firmware Corruption, T1561.001 Disk Content Wipe, T1685 Disable or Modify Tools, T1078.001 Default Accounts
- CAPEC: CAPEC-100 Overflow Buffers

- Navigator layers, including this study's layer, dotcom-era-cyber-events.json